

Scanning, Exploitation & Post-Exploitation

The workflow loop

`nmap` open ports → `service versions` (`-sV`) → `vuln hints` (NSE script, searchsploit)

Pick the most promising service

Research the version against exploit-db (searchsploit)

Craft or run the exploit against a lab target

Verify: did you get code execution / access?

Post-exploit: understand the foothold, privileges, and next destination

An efficient nmap practice

```
nmap -sC -sV -oA target 10.0.0.5
# -sC default scripts, -sV versions, -oA all formats
sudo nmap -sS -O 10.0.0.5 # stealth SYN scan + OS detection (root)
nmap -p- --min-rate 1000 10.0.0.5 # full port range fast
```

From version to exploit

Version string "Apache/2.4.29 (Ubuntu)" → searchsploit apache 2.4.29 → likely nothing for the service itself → pivot to the app behind it (admin panel version, .php interface).

Understanding your foothold

User context (www-data vs SYSTEM vs root)

What can it reach? (pivot map, network from box)

What creds/secrets exist? (configs, history, env)

What runs on the box? (cron jobs, scheduled tasks – persistence bait)

Post-exploitation restraint

Professionals gather **proof** and **access paths**, not bags of cash.

Screenshot the win, log the exact commands, note the impact, clean up any changes (within RoE), and move lightly.

The mindset: "I am mapping the adversary's road to the objective" – not "I need a shell on everything."

[← Reconnaissance: Passive & Ac...](#)

[Reporting & Professional Commu...](#)